

PLANTILLA DE REPORTE EJECUTIVO

Estructura y Contenido para Presentación en PowerPoint

Kit de Encuesta FISMA 2025 — Descripción completa diapositiva a diapositiva

"Un buen reporte ejecutivo es aquel que hace que quien lo recibe entienda en 20 minutos lo que costó 6 meses descubrir — y, sobre todo, lo que hay que hacer con ello."

INFORMACIÓN GENERAL DE LA PRESENTACIÓN

- Título: Diagnóstico de Madurez en Ciberseguridad Institucional — Resultados FISMA 2025
- Número de diapositivas: 18 diapositivas (versión completa) + 5 opcionales
- Duración estimada: 20-25 minutos (versión ejecutiva) / 45-60 minutos (versión técnica)
- Audiencia primaria: Junta de Gobierno, Consejo de Dirección, Comité de Seguridad
- Audiencia secundaria: CISO, CIO, responsables de área
- Software: Microsoft PowerPoint 365 / Google Slides / LibreOffice Impress
- Paleta de colores: Azul corporativo (#003366) | Gris neutro (#6B7280) | Rojo alerta (#DC2626) | Ámbar (#D97706) | Verde efectivo (#16A34A)

DIAPOSITIVA 1 — PORTADA

Elementos:

- Fondo: gradiente diagonal azul oscuro (#003366) a azul medio (#1E4D8C)
- Título principal (blanco, 40pt, centrado): "Diagnóstico de Madurez en Ciberseguridad"
- Subtítulo (blanco 70% opacidad, 24pt): "Resultados del Estudio FISMA 2025 — [Nombre Organización]"
- Fecha (blanco, 18pt): Abril 2026
- Logo organizativo (esquina inferior derecha)
- Referencia normativa (pie de página, 12pt, blanco 50%): "Basado en FY2025 IG FISMA Metrics v2.0 · NIST CSF 2.0 · ENS RD 311/2022 · Directiva NIS2"

DIAPOSITIVA 2 — ÍNDICE EJECUTIVO

Título: "Estructura de esta Presentación"

Contenido (lista con iconos):

-  El contexto: por qué medimos ahora
-  El resultado: nuestro Índice Global de Madurez (IGM)
-  El mapa: fortalezas y brechas por dominio
-  Las prioridades: top 5 acciones de mejora
-  El negocio: lo que cuesta no actuar (ROSI)
-  El plan: hoja de ruta propuesta

Nota al orador: "Esta presentación es un diagnóstico, no una autopsia. Estamos aquí para actuar."

DIAPOSITIVA 3 — CONTEXTO: EL MOMENTO EN QUE ESTAMOS

Título: "El Escenario de Amenazas en 2025: Datos que No Admiten Espera"

Diseño: 3 tarjetas de datos en columnas sobre fondo claro

Tarjeta 1 (rojo):

- Número grande: "+293%"
- Texto: "Incidentes críticos en España (CCN-CERT 2025 vs. 2024)"

Tarjeta 2 (ámbar):

- Número: "122.223"
- Texto: "Incidentes gestionados por INCIBE en 2025 (+26% vs. año anterior)"

Tarjeta 3 (azul):

- Número: "5.º"
- Texto: "Posición de España entre los países europeos más atacados (H1 2025)"

Párrafo de cierre (texto, 16pt):

"En este contexto, la madurez en ciberseguridad no es una opción de gestión: es una obligación institucional. Esta encuesta mide dónde estamos para que decidamos, con datos, adónde vamos."

Fuentes citadas al pie: CCN-CERT Informe Ciberamenazas 2025 | INCIBE Balance 2025

DIAPOSITIVA 4 — METODOLOGÍA: QUÉ MEDIMOS Y CÓMO

Título: "Marco Metodológico: Rigor con Propósito"

Diseño: Diagrama de flujo horizontal en 4 pasos

Paso 1 (icono documento): "60 preguntas · 14 módulos"

Paso 2 (icono gráfico): "5 niveles de madurez FISMA/NIST"

Paso 3 (icono calculadora): "IGM ponderado por dominio"

Paso 4 (icono hoja de ruta): "Plan de acción priorizado"

Tabla pequeña de marcos de referencia:

| Marco | Versión |

| --- | --- |

| NIST CSF 2.0 | Febrero 2024 |

| FISMA IG Metrics | FY2025 v2.0 |

| ENS | RD 311/2022 |

| NIS2 | Directiva 2022/2555 |

DIAPOSITIVA 5 — RESULTADO PRINCIPAL: EL IGM

Título: "Nuestro Índice Global de Madurez: ¿Dónde Estamos?"

Diseño: Elemento central dominante

Elemento principal (círculo grande, centrado):

- Interior: $IGM = [VALOR] / 5.0$
- Color del círculo: según nivel (rojo/ámbar/verde)
- Debajo del círculo: "Nivel: [NIVEL]" y "¿Efectivo? [SÍ/NO]"

Escala lateral (barra vertical con 5 niveles marcados):

- L1: Ad Hoc (rojo) | L2: Defined | L3: Consistently Implemented | L4: Managed ★ (umbral) | L5: Optimized (verde)
- Flecha indicando la posición actual de la organización

Texto interpretativo (recuadro inferior):

"El umbral de efectividad según los estándares FISMA / NIST es el Nivel 4 ($IGM \geq 3.5$). [Nombre Organización] se encuentra actualmente [por encima / por debajo] de ese umbral, con una brecha de [VALOR] puntos."

DIAPPOSITIVA 6 — GRÁFICO RADAR: PERFIL POR DOMINIO

Título: "Perfil de Madurez por Dominio: Fortalezas y Brechas"

Elemento principal: Gráfico radar (telaraña) de 10 ejes

Datos:

- Serie 1 (azul sólido): Puntuaciones actuales de la organización por módulo
- Serie 2 (rojo punteado): Umbral efectividad FISMA = 3.5
- Serie 3 (verde punteado): Nivel Optimized = 5.0

Etiquetas de los 10 ejes (abreviadas):

1. Gobernanza | 2. C-SCRM | 3. Activos/Riesgos | 4. Configuración | 5. IDAM/ZT
6. Datos/Privacidad | 7. Formación | 8. Monitorización | 9. Incidentes | 10. Continuidad

Leyenda: "● Situación actual - Umbral efectividad (L4) - Objetivo Optimized (L5)"

Texto de apoyo: "Los dominios [X] e [Y] presentan las mayores brechas respecto al umbral de efectividad FISMA. Son los candidatos prioritarios a la inversión."

DIAPPOSITIVA 7 — TABLA DE RESULTADOS POR MÓDULO

Título: "Resultados Detallados: Los 10 Dominios FISMA FY2025"

Tabla (con formato condicional de color en columna "Nivel"):

Dominio	Función CSF	Puntuación	Nivel	Efectivo	Brecha L4
I. Gobernanza	GOVERN	[X.X]	[Nivel]	✓/X	[X.X]
II. C-SCRM	GOVERN	[X.X]	[Nivel]	✓/X	[X.X]
III. Activos/Riesgos	IDENTIFY	[X.X]	[Nivel]	✓/X	[X.X]
IV. Configuración	PROTECT	[X.X]	[Nivel]	✓/X	[X.X]
V. IDAM / ZTA	PROTECT	[X.X]	[Nivel]	✓/X	[X.X]
VI. Datos/Privacidad	PROTECT	[X.X]	[Nivel]	✓/X	[X.X]
VII. Formación	PROTECT	[X.X]	[Nivel]	✓/X	[X.X]
VIII. Monitorización	DETECT	[X.X]	[Nivel]	✓/X	[X.X]
IX. Incidentes	RESPOND	[X.X]	[Nivel]	✓/X	[X.X]
X. Continuidad	RECOVER	[X.X]	[Nivel]	✓/X	[X.X]
IGM GLOBAL		[X.X]	[Nivel]	✓/X	[X.X]

DIAPPOSITIVA 8 — COMPARATIVA CON BENCHMARKS

Título: "¿Cómo Estamos Respecto a Nuestros Pares?"

Diseño: Gráfico de barras horizontales con benchmarks

Barras (de mayor a menor IGM esperado):

- FISMA Federal EE.UU. (media FY2025): 3.7
- ENISA Top Quartile EU: 3.6
- Infraestructura Crítica España: 3.4
- AAPP Autonómica media: 2.8
- **[NOMBRE ORGANIZACIÓN] – [VALOR IGM]** (barra destacada en azul corporativo)
- Sanidad pública media: 2.6
- AAPP Local media: 2.2

Línea vertical roja: Umbral efectividad L4 = 3.5

DIAPPOSITIVA 9 — TOP 5 HALLAZGOS CRÍTICOS

Título: "Los Cinco Hallazgos Más Importantes"

Diseño: 5 tarjetas numeradas en disposición 3+2 o lista vertical

Para cada hallazgo: número (grande, círculo de color), título del hallazgo (negrita), descripción breve (2 líneas), referencia normativa afectada (texto pequeño gris).

Ejemplos de hallazgos tipo:

Hallazgo 1 (rojo): Gobernanza sin métricas ejecutivas

– La dirección no recibe KPIs formales de ciberseguridad / Ref: Art. 13 ENS | Gov-2 FISMA

Hallazgo 2 (rojo): C-SCRM: proveedores sin evaluación

– El 60%+ de contratos TIC carecen de cláusulas de seguridad / Ref: Art. 19 ENS | Art. 21.2.d NIS2

Hallazgo 3 (ámbar): MFA incompleto

– MFA no implementado en todos los sistemas; usuarios estándar sin protección adicional / Ref: Art. 21.2.j NIS2

Hallazgo 4 (ámbar): Logging insuficiente

– Cobertura de registros inferior al 50%; sin retención conforme a M-21-31 / Ref: ISCM-3 FISMA

Hallazgo 5 (ámbar): BCP no probado

– Plan de continuidad existente pero sin prueba en más de 2 años / Ref: Art. 26 ENS | CP-2 FISMA

DIAPPOSITIVA 10 — ANÁLISIS DE RIESGO: LO QUE CUESTA NO ACTUAR

Título: "El Coste de la Inacción: Una Perspectiva Actuarial"

Diseño: Comparativa en dos columnas

Columna izquierda (rojo) "Sin mejoras":

- ALE anual estimado: [VALOR €]
- Probabilidad incidente mayor en 3 años: [%]
- Coste potencial worst case: [VALOR €]

Columna derecha (verde) "Con plan de mejora":

- ALE reducido: [VALOR €]
- Inversión total estimada: [VALOR €]
- ROSI: [%] | Payback: [X] meses

Texto de cierre:

"La pregunta no es si podemos permitirnos invertir en ciberseguridad. La pregunta es si podemos permitirnos no hacerlo."

DIAPPOSITIVA 11 — HOJA DE RUTA: TOP 3 ACCIONES PRIORITARIAS

Título: "Las Tres Acciones con Mayor Impacto en Madurez"

Diseño: 3 tarjetas en columnas (una por acción) con semáforo de urgencia

Para cada acción:

- Número y título de la acción
- Dominio FISMA afectado
- Nivel actual → Nivel objetivo
- Plazo estimado: [X meses]
- Coste estimado: [X €]
- Impacto en IGM: +[X] puntos
- Responsable propuesto: [Rol]
- Referencia normativa

DIAPPOSITIVA 12 — HOJA DE RUTA: VISIÓN A 18 MESES

Título: "Hoja de Ruta 2026-2027: Del Diagnóstico a la Excelencia"

Diseño: Diagrama de Gantt simplificado en 3 horizontes temporales

Horizonte 1 (Meses 1-3) — "Quick Wins":

- Acción [X]: Implementar MFA universal
- Acción [Y]: Inventario de proveedores y cláusulas contractuales
- Acción [Z]: Dashboard de KPIs de seguridad para la dirección

Horizonte 2 (Meses 4-9) — "Fundamentos":

- Programa CDM/monitorización continua
- Revisión y prueba del Plan de Continuidad
- Programa de formación por roles

Horizonte 3 (Meses 10-18) — "Madurez Sostenida":

- Implementación Zero Trust (fases 1-2)
- Certificación ENS completa
- IGM objetivo: ≥ 3.5 (Nivel 4 — Efectivo)

DIAPPOSITIVA 13 — MARCO NORMATIVO: OBLIGACIONES VIGENTES

Título: "El Entorno Regulatorio: Lo Que la Norma Ya Exige"

Tabla de tres marcos:

Marco	Estado	Obligación inmediata	Riesgo de incumplimiento
ENS (RD 311/2022)	Vigente	Categorización y adecuación	Inhabilitación de sistemas; responsabilidad directiva
NIS2	Transposición en curso (España 2025)	Gobernanza, IR 24/72h, cadena suministro	Hasta 10M€ o 2% facturación
LOPDGDD / RGPD	Vigente	Seguridad del tratamiento, notificación breaches	Hasta 20M€ o 4% facturación global

DIAPPOSITIVA 14 — COMPARATIVA FISMA/ENS/NIS2

Título: "Convergencia de Marcos: Lo Que FISMA, ENS y NIS2 Comparten"

Diagrama de Venn de tres círculos:

Zona central (los tres marcos):

- Gestión basada en riesgos
- Monitorización continua
- Notificación de incidentes
- Gobernanza de alto nivel

FISMA + ENS (sin NIS2):

- Métricas formales de madurez
- Auditoría independiente obligatoria

NIS2 + ENS (sin FISMA):

- Sanciones económicas directas
- Clasificación entidades esenciales/importantes

FISMA (exclusivo):

- Zero Trust como métrica formal
- CDM automatizado (90% cobertura)
- 5 niveles de madurez con puntuación ponderada

DIAPPOSITIVA 15 — HORIZONTE 2027: AMENAZAS EMERGENTES

Título: "Las Amenazas del Futuro (Que Ya Son del Presente)"

Tres tarjetas:

Tarjeta 1 — IA Adversarial:

- Phishing generativo, deepfakes, evasión de EDR

- Estado de preparación [NOMBRE ORG]: [NIVEL]
- Acción recomendada: actualizar controles SIEM/EDR para detección de ataques IA

Tarjeta 2 — Criptografía Post-Cuántica (PQC):

- NIST finalizó estándares FIPS 203/204/205 (agosto 2024)
- Migración necesaria antes de 2030 para sistemas de alta seguridad
- Acción recomendada: inventario de sistemas criptográficos vulnerables (H1 2026)

Tarjeta 3 — Regulación en aceleración:

- DORA (vigente enero 2025), NIS2 en transposición, CRA en aprobación
- Cada 18 meses aparece un nuevo marco normativo relevante
- Acción recomendada: función de compliance como proceso permanente, no puntual

DIAPPOSITIVA 16 — PRÓXIMOS PASOS Y PROPUESTA DE DECISIÓN

Título: "Próximos Pasos: Tres Decisiones para Hoy"

Diseño: 3 elementos de decisión en formato de tarjeta de acción

Decisión 1: ¿Aprobamos el presupuesto para las acciones prioritarias?

- Inversión requerida: [VALOR €]
- Plazo de decisión: [FECHA]
- Responsable de propuesta: CISO / CIO

Decisión 2: ¿Establecemos el Comité de Ciberseguridad de nivel directivo?

- Frecuencia: Trimestral
- Composición: DG, CISO, CIO, DPO, Responsable Legal
- Primera reunión propuesta: [FECHA]

Decisión 3: ¿Fijamos el IGM = 3.5 como KPI institucional de ciberseguridad para 2027?

- Revisión semestral del IGM con esta metodología
- Informe anual al órgano de gobierno

DIAPPOSITIVA 17 — METODOLOGÍA Y FUENTES

Título: "Notas Metodológicas y Fuentes Primarias"

Lista de fuentes:

- OMB Memorandum M-25-04 (enero 2025) — Guía FY2025 FISMA
- FY2025 IG FISMA Reporting Metrics v2.0 (3 abril 2025) — CIGIE/OMB/CISA
- NIST Cybersecurity Framework 2.0 (febrero 2024) — NIST
- NIST SP 800-53 Rev. 5 — Security and Privacy Controls
- Real Decreto 311/2022 — Esquema Nacional de Seguridad
- Directiva UE 2022/2555 (NIS2)
- Anteproyecto Ley Coordinación y Gobernanza de la Ciberseguridad (enero 2025) — DSN España
- ENISA NIS Investments 2025 (diciembre 2025)

- CCN-CERT Informe de Ciberamenazas y Tendencias 2025
- INCIBE Balance de Ciberseguridad 2025 (febrero 2026)

Advertencia: "Los resultados del diagnóstico son orientativos y se basan en autoevaluación. Para evaluación formal con validez certificatoria, se requiere auditoría independiente por entidad acreditada."

DIAPOSITIVA 18 — CIERRE

Diseño: Fondo oscuro (igual a portada)

Cita central (texto grande, blanco):

"La ciberseguridad sin métricas no es seguridad: es esperanza. Y la esperanza, como activo de gestión del riesgo, tiene una valoración actuarial particularmente baja."

Debajo:

- [Nombre del respondente / CISO]
- [Datos de contacto]
- [Fecha]

Elementos finales:

- Logo organizativo
- Referencia al kit completo de documentación: "Kit FISMA 2025 disponible en [repositorio interno]"

DIAPOSITIVAS OPCIONALES (para versión técnica extendida)

DIAPOSITIVA 19 (OPT) — Detalle de Hallazgos por Pregunta

Tabla completa de las 60 preguntas con respuestas y puntuaciones.

DIAPOSITIVA 20 (OPT) — POA&M Detallado

Tabla completa del Plan de Acción y Mejora con todas las acciones priorizadas.

DIAPOSITIVA 21 (OPT) — Análisis de Sensibilidad ROSI

Gráfico de tornado de las variables con mayor impacto en el ROSI.

DIAPOSITIVA 22 (OPT) — Detalle de Compliance ENS

Estado artículo a artículo de la adecuación al RD 311/2022.

DIAPOSITIVA 23 (OPT) — Comparativa con Encuesta Anterior

Evolución del IGM respecto a la medición anterior (si disponible).

Kit de Encuesta FISMA 2025 — Plantilla Reporte Ejecutivo PowerPoint · Versión 1.0 · Abril 2026